Fundamentals of Cybersecurity

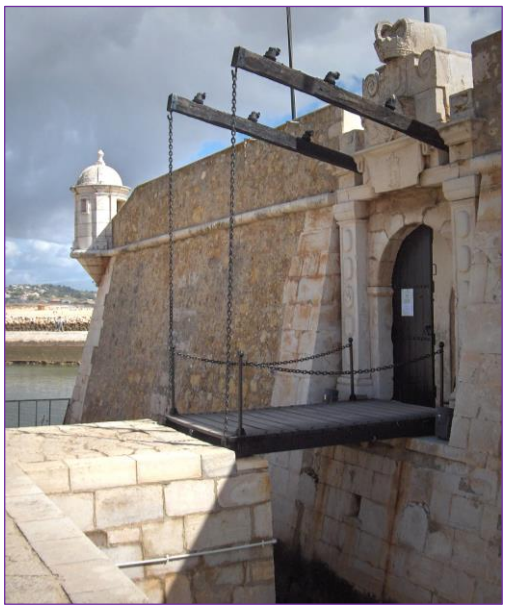
Mohammad Hosseini

Faculty of Computer Science and Engineering
Shahid Beheshti University



Network Security Countermeasures 3

Operational security



- A **single point of entry/exit** where both good guys and bad guys entering and leaving the organization are **security-checked**.

Operational security

- In a computer network, traffic entering/leaving a network should be security-checked, logged, dropped, or forwarded.
  - It is done by operational devices known as firewalls, intrusion detection systems (IDSs), and intrusion prevention systems (IPSs).
  - These are part of a **layered defense strategy**.

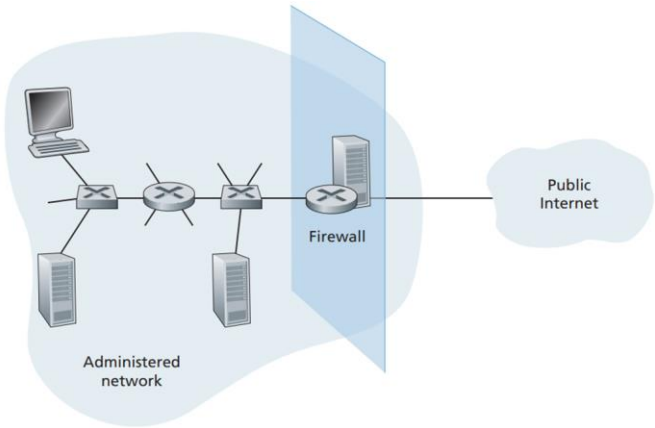
Firewall





Firewall

- A network firewall is a network security device that monitors and filters incoming and outgoing traffic based on security policies (rules).
  - Block unauthorized access.
  - Allow legitimate traffic.
- Firewalls are typically placed at the network perimeter.



Firewall

- Commercial firewalls are typically shipped as specialized hardware appliances.



- However, you can also easily create a firewall (packet filter) from a Linux box using `iptables`.
- Firewalls are now frequently implemented in routers and controlled remotely using SDNs.

Firewall types

- Firewalls can be classified in three categories:
  - Traditional packet filters
  - Stateful filters
  - Application gateways

Traditional packet filters

- A packet filter examines each datagram in isolation, determining whether the datagram should be allowed to pass or should be dropped based on administrator-specific rules.
- Filtering decisions are typically based on:
  - IP source or destination address
  - Protocol type in IP datagram field: TCP, UDP, ICMP, OSPF, and so on
  - TCP or UDP source and destination port
  - TCP flag bits: SYN, ACK, and so on
  - ICMP message type
  - Different rules for datagrams leaving and entering the network
  - Different rules for the different router interfaces

Policies

- A network administrator configures the firewall based on the policy of the organization.

Policy	Policy
No outside Web access.	Drop all outgoing packets to any IP address, port 80.
No incoming TCP connections, except those for organization's public Web server only.	Drop all incoming TCP SYN packets to any IP except 130.207.244.203, port 80.
Prevent video streaming from eating up the available bandwidth.	Drop all incoming UDP packets—except DNS packets.
Prevent your network from being used for a smurf DoS attack.	Drop all ICMP ping packets going to a "broadcast" address (eg 130.207.255.255).
Prevent your network from being tracerouted.	Drop all outgoing ICMP TTL expired traffic.

Policies

- Filtering can also be based on whether or not the TCP **ACK** bit is set.
  - E.g., an organization wants to let its internal clients connect to external servers but wants to prevent external clients from connecting to internal servers.
  - To prevent external clients from initiating connections to internal servers → simply filter all incoming segments with the **ACK** bit set to 0.

Router access control list

- Firewall rules are implemented in **routers with access control lists**, with each router interface having its own list.

action	source address	dest address	protocol	source port	dest port	flag bit
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80	any
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53	—
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023	—
deny	all	all	all	all	all	all

➢ Rules are applied to each datagram that passes through the interface from top to bottom.

Stateful packet filters

- How is this setting vulnerable?

action	source address	dest address	protocol	source port	dest port	flag bit
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80	any
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53	—
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023	—
deny	all	all	all	all	all	all

- Stateful filters track TCP connections, and use this knowledge to make filtering decisions.

Stateful packet filters

- Connection table for a stateful packet filter (firewall)

source address	dest address	source port	dest port
222.22.1.7	37.96.87.123	12699	80
222.22.93.2	199.1.205.23	37654	80
222.22.65.143	203.77.240.43	48712	80

action	source address	dest address	protocol	source port	dest port	flag bit	check connection
allow	222.22/16	outside of 222.22/16	TCP	> 1023	80	any	
allow	outside of 222.22/16	222.22/16	TCP	80	> 1023	ACK	X
allow	222.22/16	outside of 222.22/16	UDP	> 1023	53	—	
allow	outside of 222.22/16	222.22/16	UDP	53	> 1023	—	X
deny	all	all	all	all	all	all	

Application gateway

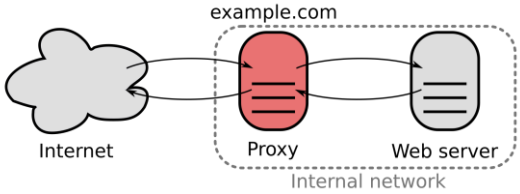
- Application gateways look beyond the IP/TCP/UDP headers and make policy decisions based on application data.
- An application gateway is an application-specific server through which all application data (inbound and outbound) must pass.
  - With this capability, it is possible to distinguish HTTP traffic used for Web browsing from HTTP traffic used for peer-to-peer file sharing.
  - E.g., web application firewall (**WAF**)

WAF

- Web Application Firewalls use various detection methods to identify and block malicious traffic targeting web applications.
- A WAF operates by inspecting HTTP/HTTPS traffic between the client (e.g., a user's browser) and the web application.
- It looks for patterns or behaviors that match known attack techniques or anomalous activities.

WAF deployment models

- Proxy-Based (Reverse Proxy)
  - The client's traffic is sent directly to the WAF. The WAF then separately sends filtered traffic to web applications.



- Transparent
  - The HTTP traffic is sent straight to the web application, and the WAF is transparent between the client and server. (It does not require changes to DNS or application configurations)
- Cloud-Based
  - A cloud provider manages the WAF, and traffic is routed through their network for filtering.

WAF detection methods

- Signature-based detection
  - Relies on a predefined database of attack signatures.
  - Signatures are specific strings, regular expressions, or sequences of operations that match known attack payloads.

  Examples:
  - `SELECT * FROM users WHERE username = 'admin' –`
  - If a request contains keywords like `' OR '1'='1` or attempts to modify a SQL query, the WAF blocks it.
  - If a request includes suspicious `<script>` tags, the WAF identifies it as a potential XSS attack.

WAF detection methods

- Behavioral analysis
  - Analyzing traffic patterns and identifying anomalies that deviate from normal behavior.
  - It flags or blocks requests that exhibit unusual patterns.

  Examples:
  - A user attempts to log in hundreds of times in a short period. The WAF detects abnormal login attempts and blocks the IP.
  - A user logs in from a new geographic location or with unusual headers, triggering an anomaly alert.
  - DDoS mitigation

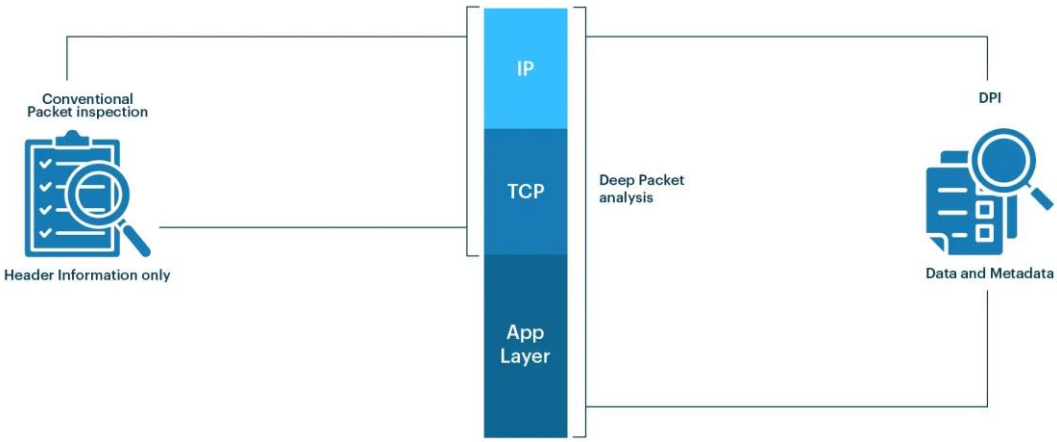
WAF detection methods

- Rule/policy-based filtering
  - Defining custom rules or policies to block or allow specific types of traffic.
  - Rules can be based on IP addresses, request headers, URLs, or payload content.

  Examples:
  - Blocking access to sensitive URLs like `/admin` or `/config`
  - Blocking requests containing specific keywords like `DROP TABLE` or `eval()`.
- AI-based detection
- Reputation-Based Detection

Deep Packet Inspection

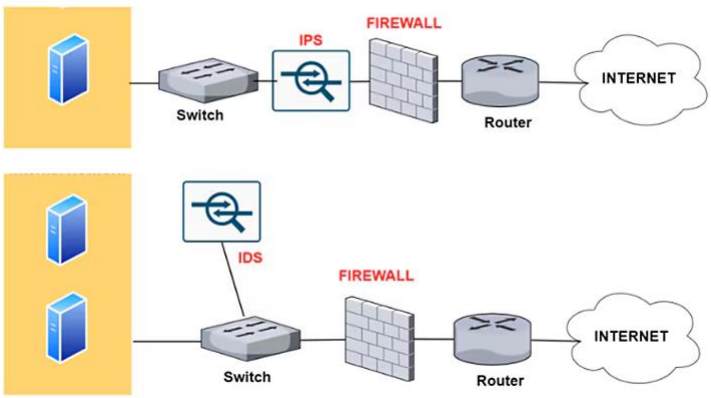
- Application gateways atually do deep packet inspection.
- DPI: looking beyond the header fields and into the actual application data that the packets carry.



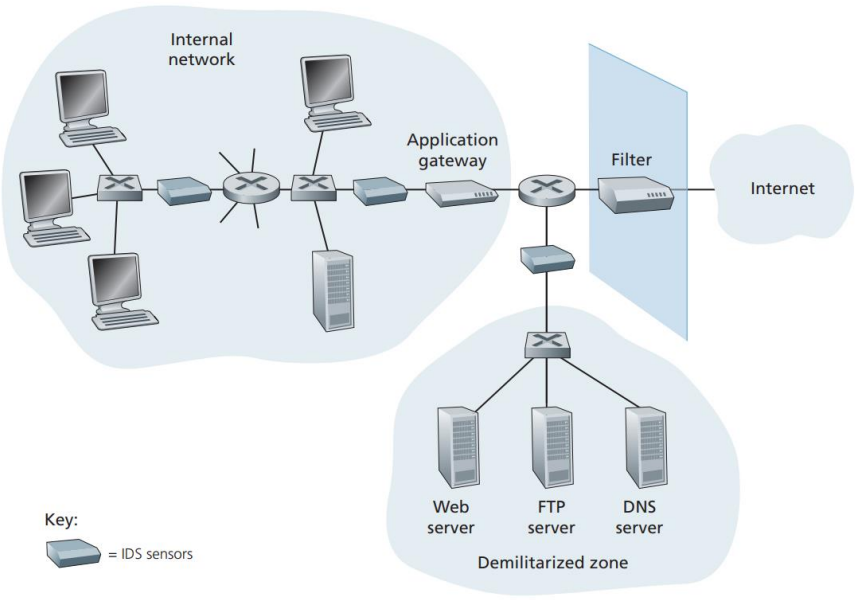
Intrusion Detection System

- An application gateway only does DPI **for a specific application**.
- Intrusion Detection System (IDS): a device that not only examines the headers of all packets passing through it (like a packet filter), but also performs deep packet inspection.
  - When It observes a suspicious packet, or a suspicious series of packets, it generates an alert.
  - An IDS can be used to detect a wide range of attacks, including network mapping, port scans, TCP stack scans, DoS bandwidth-flooding attacks, worms and viruses, OS vulnerability attacks, and application vulnerability attacks.
  - A device that filters out suspicious traffic is called an **intrusion prevention system** (IPS).

Intrusion Detection System



Intrusion Detection System



Intrusion Detection System

IDS systems are broadly classified as either signature-based systems or anomaly-based systems.

- A **signature-based** IDS maintains an extensive database of attack signatures. Each signature is a set of rules pertaining to an intrusion activity.
  - A signature may simply be a list of characteristics about a single packet (e.g., header values, or a specific string of bits in the packet payload), or may relate to a series of packets.
  - A signature-based IDS is completely blind to new attacks.
- An **anomaly-based** IDS creates a traffic profile as it observes traffic in normal operation.
  - It then looks for packet streams that are statistically unusual

Snort

- Many IDS systems are proprietary
- Snort is a **free open-source** network IDS/IPS.
  - It can run on Linux, UNIX, and Windows platforms.
  - It uses the generic sniffing interface libpcap.
  - Vast community of users and security experts that maintain its signature database.
  - Typically, within a few hours of a new attack, the Snort community writes and releases an attack signature, which is then downloaded by the hundreds of thousands of Snort deployments distributed around the world.
  - an example of a Snort signature

```
alert icmp $EXTERNAL_NET any -> $HOME_NET any
(msg:"ICMP PING NMAP"; dsize: 0; itype: 8;)
```